



Generate **SBOM**

Know what's inside your software — before someone else has to ask.

Software Bills of Materials for Python · security, licences, and compliance in one place

Prepared by **Kevin Mills** · July 2026 · Self-hosted · Open source · Apache 2.0

One dependency file in, a complete inventory out

The **Generate SBOM** project answers a question most teams can't: **what is actually inside this software?**

Upload a project's dependency manifest and, in under two minutes, the system resolves every direct and transitive library and produces a standards-based Bill of Materials alongside vulnerability, license, dependency-graph, and version-currency reports — in one dashboard, exportable, and API-accessible.

It runs entirely on your own infrastructure. No dependency data leaves your servers, and it deploys with a single **docker compose up**.

AT A GLANCE

Status

Delivered — 14 epics complete

Inputs

5 Python manifest formats

Outputs

CycloneDX JSON/XML · SPDX 2.3

Reports

Vulnerabilities, licences, graph, currency

Speed

Results in under 2 minutes (*average*)

Quality

95%+ backend test coverage

Model

Multi-tenant, self-hosted, Apache 2.0

WHY WE DID THIS

Teams can't secure or certify what they can't see

A modern Python project pulls in hundreds of libraries it never names directly. That invisible chain is exactly where risk — and regulation — now lives.

01

Security exposure

A single vulnerable library buried deep in the dependency chain is enough to expose a product. Most teams have no fast way to find it until after an incident.

02

Licence risk

Some open-source licences carry legal obligations on anyone who ships them. Without a full inventory, legal and compliance teams are working blind.

03

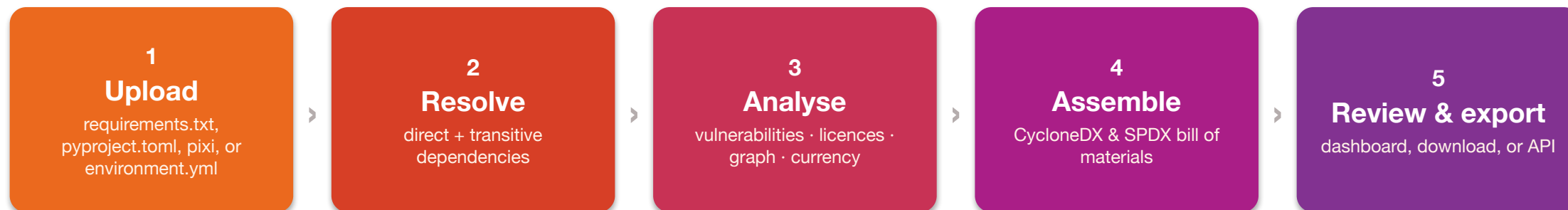
Compliance is now mandatory

The EU Cyber Resilience Act (in force 2027) requires an SBOM for products sold in the EU, and enterprise buyers increasingly demand one regardless of regulation.

And because dependency data is sensitive, everything runs self-hosted — nothing leaves your own servers.

HOW WE DID THIS — THE PRODUCT

An asynchronous pipeline from manifest to inventory



Jobs run in the background, so a large project resolves without blocking — typically in under two minutes.

BUILT ON

Django · DRF · Celery on PostgreSQL, Redis & S3-compatible storage; React + TypeScript UI

SPEAKS

CycloneDX (JSON/XML) and SPDX 2.3 — accepted by regulators, buyers, and security tools

SOURCED FROM

OSV · PyPI · conda-forge (prefix.dev) · endoflife.date

Small stories, one toolchain, a gate that can't be skipped

- **Story-driven delivery.** Every change — feature, fix, or doc — was scoped as a contexted story with explicit acceptance criteria before any code was written.
- **One command for everything.** A single toolchain (pixi) orchestrates both the Python backend and the Node frontend: build, lint, type-check, test, and docs.
- **A quality gate on every merge.** Formatting, strict type-checking, linting, a security scan, and the full test suite must all pass before anything lands — enforced, not optional.
- **Reviewed, isolated changes.** Each feature and fix rode its own branch into a small pull request; nothing was committed straight to the main line.

THE MERGE GATE

- ✓ format
- ✓ type-check (strict)
- ✓ lint
- ✓ security scan
- ✓ full test suite — 90% floor
- ✓ package & docs build

Achieved: 95%+ backend coverage

THE OUTCOME

A working platform, not a prototype

14

epics delivered

95%+

test coverage

5 → 3

formats in / out

<2 min

typical run

10 days

auto-retention

WHAT SHIPPED

- **Standards-based SBOM** CycloneDX JSON/XML and SPDX 2.3
- **Viewable in-app or downloadable**, now with per-component licenses embedded in the document.
- **The full report suite** Vulnerabilities, licenses, dependency graph, and version currency — each with a formatted Excel export.
- **Multi-tenant access** Full isolation between organizations and a guarded two-tier admin model (organization admin and global administrator).
- **Docs, API & deploy** A published documentation site, a complete REST API with an interactive schema, and a one-command docker compose deployment.

From inventory to continuous assurance

NEAR-TERM

SBOM in the pipeline

Generate and gate on every build through the API and CI, so the inventory is never stale.

Scheduled re-scans & drift alerts

Re-check existing projects and notify when a new vulnerability lands on a dependency you already ship.

MID-TERM

Signing & provenance

Attest SBOMs (e.g., Sigstore) so downstream consumers can trust where they came from.

VEX support

Record exploitability so teams triage the vulnerabilities that affect them, not just the ones that exist.

LONGER-TERM

Beyond Python

Extend dependency resolution to additional package ecosystems.

Configurable conda solve

Platform and CUDA-aware solving — the one item deliberately deferred from this phase.

The through-line: move from a point-in-time snapshot to continuous, verifiable assurance.

REFERENCE

Terms & abbreviations

SBOM

Software Bill of Materials — a machine-readable inventory of every component in a piece of software.

CycloneDX

An OWASP SBOM standard; the app emits both JSON and XML.

SPDX

A Linux Foundation SBOM standard (version 2.3 supported here).

CVE

Common Vulnerabilities and Exposures — a public identifier for a known security flaw.

VEX

Vulnerability Exploitability eXchange — a statement of whether a known flaw affects a product.

Transitive dependency

A library pulled in indirectly by another dependency, not declared by you directly.

Manifest

The file that declares a project's dependencies (e.g., requirements.txt, pyproject.toml).

OSV

Open-Source Vulnerabilities — a distributed vulnerability database for Open-Source projects.

PyPI

The Python Package Index — the primary source of Python packages.

conda-forge

A community-run package repository for the conda ecosystem.

Version currency

How far behind the latest release each dependency is running.

EOL / LTS

End of Life / Long-Term Support — whether a version still receives updates.

Copyleft / Permissive

Licence families; copyleft can impose obligations on distributed software, permissive generally does not.

CRA

EU Cyber Resilience Act — regulation requiring an SBOM for products sold in the EU (effective 2027).

Global admin

An account that administers the whole installation across every organisation.



Generate **SBOM**

**Know what's inside your software —
before someone else has to ask.**

Self-hosted · open source · Apache 2.0 — deployable in minutes with a single command.
Full documentation and REST API ship with the platform.

Questions welcome.